

AGENT workflow 静态扫描三期灵镜适配特性

1 特性概述[必需]

当前，行内 Agent 应用以 Workflow 编排形态为主，开发平台及资产格式逐步多元化。第一期已完成面向 Dify 平台、采用 YAML DSL 的 workflow 静态安全扫描能力；第二期进一步适配行内自研 AI 智能工厂、采用 JSON DSL 的 workflow，在解析映射、语义建模、平台特有风险识别及测试输入簇生成等方面形成补充能力。现阶段两类能力已具备独立扫描基础，但仍缺少面向行内用户的统一服务入口与平台化管理能力。

本期特性聚焦既有 AGENT workflow 静态扫描能力向灵镜平台的统一接入与运营化承载。相较一期、二期主要解决“扫描能力分散、使用方式偏工具化、任务与报告缺少统一管理”的问题，通过一事通鉴权、统一上传入口、任务状态管理、报告预览下载及审计留痕，将原有扫描工具升级为可访问、可管控、可追溯的安全服务。

在扫描链路上，本期不重复建设 YAML、JSON 的底层检测逻辑，而是增加 DSL 类型与平台方言识别、解析适配路由及统一结果契约：YAML 文件进入 Dify 适配流程，JSON 文件进入 AI 智能工厂适配流程，并统一映射为 workflow 语义模型，再执行通用规则与平台特有规则分析。报告侧补充 workflow 拓扑展示、风险节点与传播路径定位，并区分用户版与维护者版视图，兼顾业务使用和规则维护。

本期建设边界为静态扫描能力的灵镜适配与平台化，不新增动态执行能力。通过“平台接入层—资产适配层—统一语义层—规则分析层—结果服务层”的分层方式，为后续开展动态安全验证，以及进一步接入以 Python、Java 等语言自主开发的高码 Agent 预留扩展接口，逐步形成覆盖低码 Workflow 与高码 Agent 的统一安全检测体系。

本期定位：对一期、二期既有扫描能力进行统一封装和平台化承载；核心增量是灵镜适配、格式路由、任务治理、结果可视化与维护闭环。

2 关联专题衡量指标[按需]

本期可围绕平台覆盖、扫描一致性和过程可追溯性设置衡量维度；具体量化目标在联调及验收阶段结合灵镜平台要求确认。

衡量维度	指标说明	建议判定方式
资产覆盖	统一入口覆盖 Dify YAML 与 AI 智能工厂 JSON 两类既有工作流资产。	以已纳入测试集的两类样例完成上传、识别和扫描为准。
适配正确性	能够识别 DSL 类型及平台方言，并分发至对应解析适配流程。	正确路由；不支持或异常文件给出明确提示。
结果一致性	门户扫描结果与原扫描能力的核心问题数量、等级和证据保持一致。	同一输入的结构化结果与报告统计可核对。
任务可追溯	用户、文件、扫描任务、报告及复核记录形成关联。	能够按任务编号查询完整处理链路。
治理闭环	维护者可复核待确认问题并沉淀规则优化依据。	复核结论可记录、查询和导出。

3 特性全景

3.1 特性全景描述[必需]

三期整体能力由平台接入、统一扫描、结果治理三个层面构成。平台接入负责灵镜菜单、身份权限、文件工作区和服务接口适配；统一扫描负责 DSL 识别、格式路由、语义归一和规则分析；结果治理负责风险定位、报告展示、维护者复核及规则反馈。功能全景如下表所示。

序号	分类	功能简述
1	门户服务化接入	将既有工作流扫描能力封装为灵镜内可访问的页面化安全服务。
2	灵镜嵌入与身份承接	适配灵镜菜单、路由和页面布局，复用一事通身份及平台权限。
3	文件上传与工作区隔离	接收 DSL 及关联材料，为每次上传创建相互隔离、可追溯的扫描工作区。
4	DSL 类型识别与适配路由	识别 YAML/JSON 及对应平台方言，并进入相应解析与字段映射流程。
5	工作流语义建模	将不同格式的节点、连线、变量和调用关系归一为统一语义对象。
6	工作流拓扑展示	根据语义模型生成可视化流程图，支持节点、链路与扫描结果关联。
7	静态扫描任务管理	统一创建、执行、查询和重试扫描任务，记录发起人及处理状态。
8	安全规则分析	复用通用安全规则，并结合平台字段映射执行平台特有风险检测。
9	风险解析与节点定位	对原始命中进行标准化、分级、聚合和证据绑定，定位风险节点及影响路径。
10	报告预览与下载	在门户展示风险概览和问题明细，并提供 HTML、PDF、JSON 等结果下载。
11	用户版与维护者版双视图	用户版聚焦风险结论，维护者版承载原始命中、待复核项及规则优化依据。
12	平台接口与数据适配	统一上传、任务、状态和报告接口契约，完成存储、元数据及迁移适配。

3.2 业务流程图[必需]

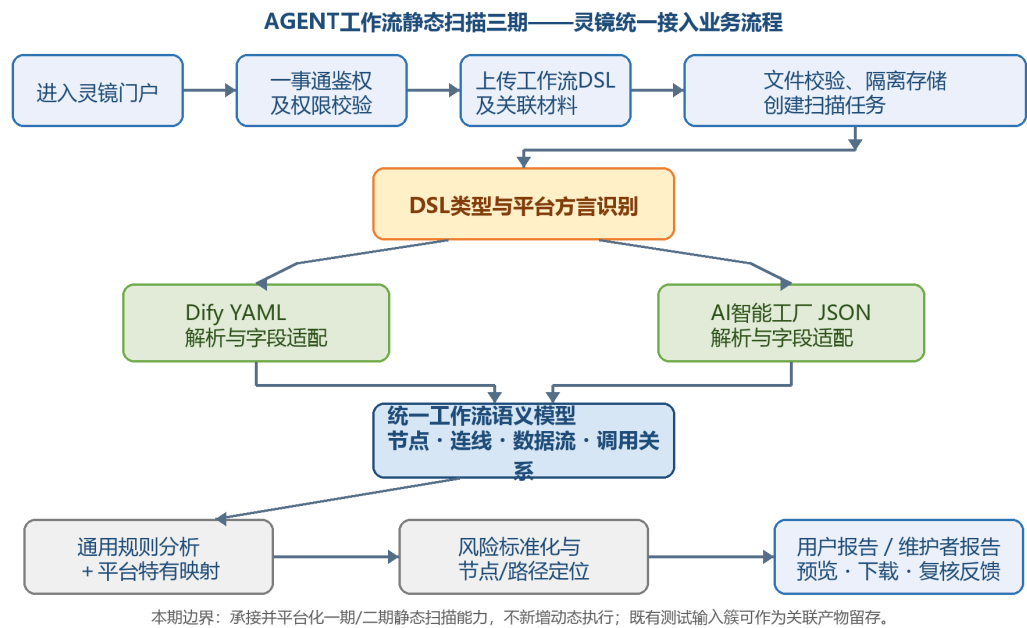


图3.1 AGENT workflow 静态扫描三期——灵镜适配业务流程图

用户经灵镜平台进入 workflow 安全扫描门户，系统承接一事通身份并完成权限校验。用户上传 DSL 文件及可选关联材料后，系统进行文件校验、隔离存储和任务登记，并依据文件结构及关键字段识别 DSL 类型和平台方言。YAML/Dify 与 JSON/AI 智能工厂分别进入对应适配流程，随后归一为统一工作流语义模型；在此基础上执行通用规则和平台特有规则分析，将结果标准化并绑定至具体节点或路径，最终形成面向用户和维护者的差异化报告。

3.3 原型说明[按需]

页面原型建议沿用已审批 Skill 灵镜适配特性的交互基线，保持入口、任务状态和报告操作的一致性，并增加 workflow 资产所需的 DSL 信息、拓扑图和节点风险定位区域。

页面/区域	主要展示内容	workflow 特有设计
workflow 安全扫描	文件上传、格式识别结果、扫描说明、任务发起。	展示 DSL 类型、平台来源、节点数量及解析状态。
扫描任务	任务编号、发起人、创建时间、当前阶段、执行结果。	区分文件解析、语义建模、规则分析和报告生成阶段。
报告中心	风险统计、问题清单、筛选、预览和下载。	提供 workflow 拓扑视图，并支持由问题跳转至风险节点或路径。
维护者视图	原始命中、过滤原因、置信度、复核状态和导出。	沉淀平台方言差异、误报原因和规则优化依据。

4 特性说明

4.1 功能说明[必需]

4.1.1 功能描述

4.1.1.1 灵镜门户与身份接入能力

将一期、二期形成的工作流扫描能力由工具调用方式封装为灵镜内统一门户。门户不单独建设账号体系，承接灵镜菜单、路由、用户身份和权限控制，并通过服务接口触发扫描与访问报告。

能力项	说明
门户嵌入	支持灵镜一级/二级菜单、页面路由、布局及部署路径适配。
身份承接	复用一事通登录状态及用户标识，按平台授权控制扫描和报告访问。
服务封装	将文件上传、任务创建、状态查询和报告访问封装为统一服务能力。
审计留痕	记录任务发起人、时间、资产、处理结果及报告访问行为。

4.1.1.2 文件上传、存储与扫描工作区能力

门户接收工作流 DSL 文件及必要的运行样例、配置说明等关联材料。后端为每次上传建立独立工作区，并将文件、任务和报告建立关联，满足隔离、追踪及后续维护需要。

处理环节	功能要求
上传校验	校验文件类型、大小、名称和路径，拒绝目录穿越、非法后缀及异常结构。
工作区隔离	按用户或任务创建独立扫描空间，避免不同任务文件相互覆盖或越权访问。
存储关联	工作流原文件与报告分区存储，元数据记录任务编号、文件标识和报告位置。
生命周期	支持任务失败后的安全重试，并按平台策略清理临时文件、保留必要审计信息。

4.1.1.3 DSL 解析适配与工作流语义建模能力

该能力是三期区别于通用文件扫描门户的核心适配点。系统先识别 DSL 格式及平台方言，再调用对应解析适配器，将平台差异转换为统一工作流语义对象，使后续规则、拓扑图和报告不依赖原始 YAML/JSON 字段结构。

步骤	YAML / Dify	JSON / AI智能工厂	统一输出
类型识别	识别 Dify 应用及工作流关键字段。	识别智能工厂节点及编排关键字段。	平台类型、DSL 版本、解析状态。

步骤	YAML / Dify	JSON / AI智能工厂	统一输出
结构解析	提取节点、连线、变量、模型和工具配置。	提取节点对象、边关系、参数及调用配置。	节点、边、数据流、调用关系。
语义映射	将 Dify 节点类型映射至标准节点语义。	将自研节点类型映射至标准节点语义。	统一 workflow 语义模型。
异常处理	对缺失字段、版本差异给出可定位提示。	对未知节点、嵌套结构给出可定位提示。	结构化解析告警，不误进入规则分析。

处理逻辑：识别 DSL → 选择解析适配器 → 构造统一语义模型 → 执行通用规则及平台特有映射 → 输出标准化风险结果。

4.1.1.4 安全规则分析与风险解析能力

安全规则分析负责判定“是否命中风险”，风险解析负责把命中结果转换为“用户能够理解和追溯的风险”。二者使用同一套规则标识和证据来源，但职责不同：前者完成规则计算，后者完成标准化、分级、聚合、节点绑定及复核状态判定。

能力层	主要处理	形成结果
通用规则分析	基于统一语义模型检查模型配置、工具调用、输入输出、知识库及数据流等共性风险。	规则原始命中及证据。
平台特有分析	根据 Dify 或 AI 智能工厂字段、节点和配置差异补充平台专属判断。	平台特有规则命中。
风险解析	对命中结果去重、分级、聚合并补充说明、建议、置信度与复核状态。	标准化风险条目。
节点/路径定位	将风险证据绑定至节点、连线或传播路径，在拓扑图中突出展示。	可视化定位及影响链路。
测试输入簇关联	承接一期、二期已定义的定向测试输入簇产物（如有），按风险与任务关联保存。	供后续动态验证使用；本期不执行动态测试。

4.1.1.5 扫描任务与状态管理能力

系统以任务为主线组织上传文件、解析过程、规则执行和报告产物，避免用户直接操作底层命令。页面应持续反馈当前阶段，对失败任务提供明确原因和受控重试能力。

任务阶段	状态展示	控制要求
文件接收	上传中、校验中、校验失败。	防重复提交；异常文件不进入解析。
DSL 解析	类型识别、结构解析、语义建模。	记录适配器类型与解析告警。
规则分析	待执行、执行中、已完成、失败。	保证同一任务状态真实、可查询、可追溯。
报告生成	生成中、可预览、可下载。	报告与任务及源文件——关联。

任务阶段	状态展示	控制要求
异常处置	失败原因、重试状态。	重试保持幂等，不覆盖其他任务产物。

4.1.1.6 报告展示、双视图与规则治理能力

报告服务在保持结构化结果一致的基础上，为普通用户和扫描维护者提供不同信息密度。用户侧关注风险结论和整改建议，维护者侧关注原始命中、过滤过程、待确认项及规则优化依据；工作流拓扑图作为两类视图的共同定位入口。

视图/产物	展示重点	用途
用户版报告	总体风险、等级分布、问题摘要、节点定位、整改建议及准入结论。	业务自查、整改和审批留档。
维护者版报告	原始命中、过滤原因、置信度、待复核项、平台差异及导出能力。	误报复核、规则优化和测试集维护。
工作流拓扑	节点及连线关系、风险标记、问题到节点/路径的双向定位。	快速理解风险所处业务链路。
结构化产物	HTML、PDF、JSON 及可选测试输入簇关联信息。	在线预览、归档及后续系统集成。
复核反馈	记录确认风险、误报、证据不足等结论并支持导出。	形成可回溯的安全库改进依据。

4.1.2 验收标准

验收域	验收要点	结果要求
平台接入	灵镜菜单、路由、页面布局及一事通身份信息能够正常承接。	授权用户可访问；未授权访问被拦截并提示。
文件与任务	上传校验、工作区隔离、任务创建、状态查询及失败重试链路完整。	文件、任务和报告关联正确，无越权和相互覆盖。
DSL 适配	Dify YAML 与 AI 智能工厂 JSON 均能被正确识别并进入对应适配流程。	支持样例解析成功；异常或不支持文件给出明确原因。
语义与拓扑	节点、连线、变量和调用关系能够归一并生成工作流拓扑。	拓扑关系与原 DSL 一致，关键节点信息可查询。
规则与风险	通用规则和平台特有规则正常执行，风险完成分级、聚合和证据绑定。	核心结果与一期、二期原扫描能力保持一致。
报告输出	用户版、维护者版及 HTML/PDF/JSON 的核心统计和风险结论一致。	报告可预览、可下载，风险可定位至节点或路径。
治理闭环	待复核问题可记录结论并导出，规则编号与证据链可追溯。	复核数据能够作为后续规则优化输入。

4.2 安全性评估[按需]

请评估是否涉及以下特性功能，如涉及，请勾选。

评估类别	涉及项	本期判断
用户认证与授权	平台登录状态、用户身份和菜单/报告访问权限。	☒ 涉及（复用灵镜及一事通能力）
互联网文件与数据输入输出	工作流文件上传、报告下载、扫描参数输入。	☒ 涉及
敏感数据处理	是否包含个人信息、三级及以上数据。	☐ 需由业务按实际上传内容确认
会话与审计	任务发起、报告访问及维护者复核留痕。	☒ 涉及

涉及项应依据我行《应用系统安全需求规范》及灵镜平台现有安全要求落实；对上传内容的数据等级和留存期限需在线上进一步确认。

4.3 非功能需求[按需]

类别	要求
兼容性	兼容既有 Dify YAML 与 AI 智能工厂 JSON 样例；通过适配器机制隔离平台版本差异。
可靠性	扫描任务异步执行、状态可查询；失败原因明确，受控重试保持幂等。
安全性	落实文件类型、大小、路径校验，工作区隔离、访问控制、下载鉴权和必要审计。
可维护性	统一规则编号、语义模型和报告契约；平台特有逻辑集中在适配层管理。
可扩展性	后续新增 DSL 平台或 Python/Java 高码 Agent 时，通过新增资产适配器和分析插件接入。
性能	页面持续反馈任务阶段，避免长耗时扫描造成无响应；具体并发和时限指标待联调确认。

4.4 涉及的系统/组件/功能清单[按需]

序号	系统/组件	本期职责或改造内容
1	LT80.01_smirror_mgt_backend	承载文件接收、DSL 适配路由、任务编排、扫描调用、报告及复核数据服务。
2	LT80.01_smirror_frontend_react	新增工作流安全扫描、任务状态、拓扑报告和维护者复核相关页面。

序号	系统/组件	本期职责或改造内容
3	既有 YAML/JSON 静态扫描能力	作为扫描引擎被服务化调用，保持既有规则与核心结果一致。
4	COS / file_record 等存储能力	分区保存上传文件与报告，记录文件元数据、任务关联和访问位置。
5	灵镜平台 / 一事通	提供统一入口、菜单路由、身份认证、权限承接及部署运行环境。
6	工作流任务与复核数据	新增或复用任务记录，保存状态、结果摘要、复核结论及审计信息。

5 特性投入估算[按需]

待结合灵镜平台接口联调范围、前后端页面工作量、存储改造方式及 YAML/JSON 回归测试集规模进一步评估。

6 期望上线时间[必需]

2026-09（待确认）